

Defensa Adaptativa para APIs en el Borde mediante Teoría de Juegos Estocásticos: equilibrando Seguridad y Sostenibilidad Energética

Equipo *Stochastic Green Edge* (SGE)

Prototipo de investigación en Ciberseguridad Cloud y Green Computing

July 18, 2026

Resumen

La inspección profunda y sistemática de todo el tráfico entrante hacia una API pública ofrece máxima seguridad pero incurre en un costo energético elevado y constante, en tensión con los objetivos de la *computación sostenible* (Green Computing). Este trabajo propone **Stochastic Green Edge** (SGE), un mecanismo de defensa perimetral de dos capas (*Edge* ligero y *Serverless* de inspección profunda) que decide, en tiempo real y por cada petición sospechosa, si escalar a la inspección costosa. La decisión se formula como un *juego estocástico no cooperativo con información imperfecta* entre un Defensor y un Atacante, y se resuelve calculando el *Equilibrio de Nash en estrategias mixtas*. Sobre una simulación de 3000 peticiones con una mezcla realista (80% legítimo, 15% bots ruidosos, 5% ataques dirigidos) y promediando 20 semillas, SGE alcanza una mitigación global del 95.5% y del 81.8% para ataques avanzados, consumiendo un 86.8% menos de energía que el enfoque tradicional de inspección del 100%. Mostramos además la frontera de compromiso seguridad-energía y cómo el equilibrio de Nash concentra adaptativamente la energía costosa en el tráfico de mayor riesgo.

Palabras clave: Teoría de Juegos, Equilibrio de Nash, Seguridad de APIs, Edge Computing, Serverless, Green Computing, Juegos Estocásticos.

1 Introducción

Las APIs públicas son un vector de ataque crítico: reciben tráfico heterogéneo que combina usuarios legítimos, bots automatizados ruidosos y adversarios dirigidos y sigilosos. La práctica habitual de someter cada petición a una inspección profunda (sanitización exhaustiva, validación criptográfica, análisis de payload) maximiza la detección pero impone un consumo de CPU y energía elevado y *constante*, independientemente del riesgo real de cada petición. Este patrón entra en conflicto directo con la computación sostenible, que busca minimizar los ciclos de cómputo y la huella energética [5].

La observación central de este trabajo es que la may-

oría del tráfico no justifica el costo de la inspección profunda: el tráfico legítimo debe servirse con energía mínima y los bots ruidosos pueden frenarse de forma barata en el borde mediante *rate-limiting*. Únicamente una fracción pequeña y sigilosa (ataques dirigidos que imitan tráfico legítimo) requiere realmente la capa costosa. El problema es que esa fracción **no es observable** de forma directa: el defensor opera bajo *información imperfecta*.

Proponemos modelar la decisión de escalado como un juego no cooperativo entre el Defensor y el Atacante y resolver el *Equilibrio de Nash en estrategias mixtas*, obteniendo una política de escalado *aleatorizada* que es óptima en el sentido de la teoría de juegos: ninguna de las partes puede mejorar su utilidad esperada desviándose unilateralmente. Nuestras contribuciones son:

- Una arquitectura perimetral de dos capas (Edge + Serverless) con un modelo de costo energético explícito, incluida la penalización por *Cold Start*.
- La formulación del escalado como un juego bimatriz 2×2 y un motor que calcula su Equilibrio de Nash en estrategias mixtas por enumeración de soportes.
- Una evaluación empírica reproducible que cuantifica el compromiso seguridad-energía frente a líneas base y traza su frontera de Pareto.

2 Trabajo relacionado

La teoría de juegos se ha aplicado extensamente a la seguridad (*security games*), modelando la asignación de recursos de defensa frente a un adversario racional [3, 4]. Los *juegos estocásticos* de Shapley [2] y su extensión a información imperfecta capturan entornos donde el estado evoluciona y los jugadores no observan por completo las acciones del rival. El concepto de *Equilibrio de Nash* [1] en estrategias mixtas es la solución estándar cuando no existe un equilibrio en estrategias puras, como ocurre en interacciones de tipo *matching pennies*. Paralelamente, la computación sostenible y el *cómputo consciente de la energía* [5] promueven arquitecturas que ajustan dinámicamente el gasto de recursos. Nuestro trabajo sitúa la

decisión de inspección profunda en la intersección de ambos campos: usa el equilibrio de Nash como criterio para gastar energía *solo cuando el riesgo esperado lo justifica*.

3 Modelo del sistema

SGE simula dos capas de infraestructura cloud (Figura 2 ilustra su costo relativo):

Capa Edge (filtro ligero). Función de paso rápido con costo energético mínimo ($C_{\text{edge}} = 1$ unidad). Extrae métricas baratas de la petición HTTP —frecuencia de la IP de origen, tamaño del payload, anomalía del *User-Agent* y anomalía estructural del payload— y ejecuta el *cerebro matemático* (el motor de Nash). Aplica además *rate-limiting* que frena los bots ruidosos (alta frecuencia de IP y firma de agente anómala) sin invocar la capa costosa. Los ataques avanzados imitan tráfico legítimo y *no* son detenidos aquí.

Capa Serverless (inspección profunda). Función robusta que realiza sanitización exhaustiva y validación criptográfica del payload. Permanece inactiva salvo que el modelo decida activarla. Su costo de ejecución es $C_{\text{exec}} = 15$ unidades y, tras un periodo de inactividad, incurre en *Cold Start* con costo $C_{\text{cold}} = 25$ unidades. Cuando se invoca, detecta de forma fiable cualquier clase de ataque.

Los valores de energía (Joules/ciclos relativos) siguen la relación $C_{\text{edge}} : C_{\text{exec}} : C_{\text{cold}} = 1 : 15 : 25$, reflejando el elevado sobrecoste de la inspección profunda y el arranque en frío típico del cómputo sin servidor.

4 Formulación como juego

Modelamos cada petición *sospechosa* como una interacción de un solo tiro (una etapa del juego estocástico) entre dos jugadores.

Jugadores y acciones. El **Defensor** elige entre dos estrategias puras:

- D_V (*Verde*): permanecer en la capa Edge (energía mínima).
- D_A (*Activa*): escalar a la inspección Serverless.

El **Atacante** elige entre:

- A_L (*Ligero*): ataque ruidoso/automatizado.
- A_M (*Avanzado*): ataque dirigido y sigiloso.

El Defensor juega D_V con probabilidad p y D_A con probabilidad $1 - p$; el Atacante juega A_L con probabilidad q y A_M con $1 - q$.

Función de utilidad del Defensor. La utilidad del Defensor ante el par de acciones (a, d) es

$$U_D(a, d) = \alpha R(a, d) - \beta C_{\text{energy}}(d) - \gamma C_{\text{damage}}(a, d), \quad (1)$$

donde R es la recompensa por detección o por procesar tráfico legítimo con energía mínima, C_{energy} es el costo energético de la acción defensiva, C_{damage} penaliza severamente que un ataque avanzado evada la seguridad por quedarse en el borde, y $\alpha, \beta, \gamma \geq 0$ son pesos de ponderación configurables.

Modulación por sospecha (información imperfecta). El Defensor no observa la clase real de la petición; solo infiere una *puntuación de sospecha* $s \in [0, 1]$ a partir de las métricas del Edge, con la anomalía de payload como señal dominante (es lo que solo la inspección profunda puede detectar):

$$s = 0.15 \phi_{\text{ip}} + 0.15 \phi_{\text{ua}} + 0.70 \phi_{\text{payload}}, \quad (2)$$

siendo $\phi_{\text{ip}} = 1 - e^{-\text{freq}/6}$ la saturación de la frecuencia de IP. La sospecha escala el riesgo, $\rho = s_0 + (1 - s_0)s$ con piso $s_0 = 0.15$, y con él la severidad del daño $C_{\text{damage}} = D_0 \rho$ y la ganancia de brecha del atacante. Así, el equilibrio resultante es *específico de cada petición*.

Matrices de pago. Con los parámetros del prototipo ($\alpha = \beta = \gamma = 1$, $R_{\text{edge}} = 10$, $R_{\text{deep}} = 12$, $D_0 = 140$, ganancia de brecha $G_0 = 200$, costo de ataque avanzado $K = 20$, penalizaciones de detección 5 y 15) se construyen las matrices del Defensor **A** y del Atacante **B** (filas D_V, D_A ; columnas A_L, A_M):

$$A_{D_V, A_L} = \alpha R_{\text{edge}} - \beta C_{\text{edge}} \quad (3)$$

$$A_{D_V, A_M} = -\beta C_{\text{edge}} - \gamma C_{\text{damage}} \quad (4)$$

$$A_{D_A, \cdot} = \alpha R_{\text{deep}} - \beta C_{\text{serverless}} \quad (5)$$

El pago (D_V, A_M) es fuertemente negativo (brecha), mientras que D_A neutraliza el ataque a costa de energía. Esta estructura es de tipo *matching pennies*: el Defensor prefiere D_V frente a A_L pero D_A frente a A_M , y el Atacante prefiere A_M frente a D_V pero A_L frente a D_A . En consecuencia *no existe equilibrio en estrategias puras* y la solución es un equilibrio completamente mixto.

5 Equilibrio de Nash en estrategias mixtas

En un juego bimatriz 2×2 sin equilibrio puro, el equilibrio mixto se obtiene por el *principio de indiferencia*: cada jugador aleatoriza de modo que su rival sea indiferente entre sus dos acciones.

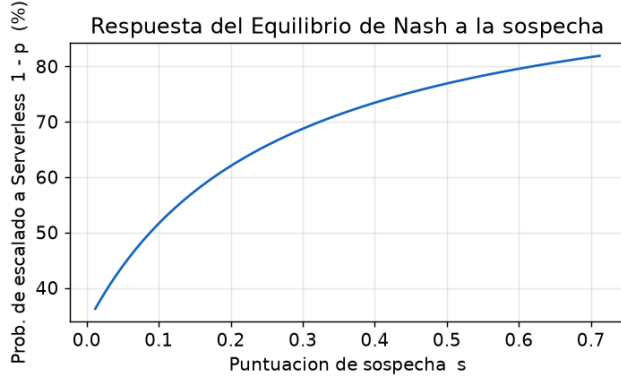


Figura 1: Respuesta del Equilibrio de Nash: probabilidad de escalar a la capa Serverless ($1 - p$) en función de la puntuación de sospecha s . El escalado es despreciable para tráfico benigno y crece con la anomalía del payload.

La probabilidad p (jugar D_V) hace al Atacante indiferente entre A_L y A_M :

$$p B_{D_V, A_L} + (1-p) B_{D_A, A_L} = p B_{D_V, A_M} + (1-p) B_{D_A, A_M}, \quad (6)$$

$$p = \frac{B_{D_A, A_M} - B_{D_A, A_L}}{(B_{D_V, A_L} - B_{D_A, A_L}) - (B_{D_V, A_M} - B_{D_A, A_M})}. \quad (7)$$

Análogamente, q (jugar A_L) hace al Defensor indiferente entre D_V y D_A :

$$q = \frac{A_{D_A, A_M} - A_{D_V, A_M}}{(A_{D_V, A_L} - A_{D_V, A_M}) - (A_{D_A, A_L} - A_{D_A, A_M})}. \quad (8)$$

El motor (`sge/game_theory.py`) implementa la enumeración de soportes: primero busca el equilibrio interior mixto por (7)–(8) y, si no es válido ($p, q \notin [0, 1]$), recurre a un equilibrio en estrategias puras por mejor respuesta mutua. Como validación, para el juego de *matching pennies* el motor devuelve $p = q = 0.5$.

Ejemplo resuelto. Para una petición con alta anomalía de payload ($s = 0.712$), las matrices son

$$\mathbf{A} = \begin{pmatrix} 9.00 & -106.73 \\ -3.00 & -3.00 \end{pmatrix}, \quad \mathbf{B} = \begin{pmatrix} -5.00 & 131.04 \\ -5.00 & -35.00 \end{pmatrix}.$$

Aplicando (7)–(8) se obtiene el equilibrio mixto $p = 0.181$ (jugar Verde) y $q = 0.896$: el Defensor **escala a Serverless con probabilidad $1 - p = 0.819$** , concentrando la energía en el tráfico de alto riesgo. La Figura 1 muestra cómo la probabilidad de escalado crece monótonamente con la sospecha.

6 Metodología experimental

Generación de tráfico. Simulamos un flujo constante con la mezcla 80% usuarios legítimos, 15% bots ruidosos (A_L) y 5% hackers dirigidos (A_M). Los legítimos

Tabla 1: Comparación de enfoques (media $\pm$ desv. est. sobre 20 semillas, $n = 3000$). Energía en Joules simulados.

Enfoque	Mit. global	Mit. avanz.	Energía
Tradicional (100%)	100%	100%	45,010
Adaptativo (Nash)	95.5%	81.8%	5,922
Edge-only (0%)	74.0%	0%	3,000

usan IP diversa, agente de navegador y payload pequeño y limpio; los bots concentran pocas IPs (alta frecuencia) con agentes anómalos (`curl`, `sqlmap`); los avanzados usan agente cuasi-normal y payload voluminoso con *tokens* de inyección.

Líneas base. Comparamos SGE (Adaptativo) contra: (i) **Tradicional**, que inspecciona el 100% del tráfico en Serverless (máxima seguridad, energía $C_{\text{cold}} + (n - 1)C_{\text{exec}}$); y (ii) **Edge-only**, que nunca escala (energía mínima $n C_{\text{edge}}$ pero 0% de mitigación de ataques avanzados).

Métricas. Tasa de mitigación global y de ataques avanzados, energía total consumida (Joules simulados) y energía ahorrada frente al enfoque tradicional. Reportamos media y desviación estándar sobre 20 semillas con $n = 3000$ peticiones. Todos los experimentos son reproducibles mediante `python3 paper/run_experiments.py`.

7 Resultados

La Tabla 1 resume la comparación principal. SGE mitiga el 95.5% del total de ataques y el 81.8% de los ataques avanzados, mientras reduce el consumo energético en un **86.8%** respecto al enfoque tradicional (de 45,010 a $\sim 5,922$ Joules). El enfoque Edge-only, aunque minimiza la energía, deja pasar la totalidad de los ataques avanzados (0% de mitigación), lo que confirma que la capa profunda es imprescindible para la fracción sigilosa.

Frontera de compromiso. La Figura 3 traza la frontera seguridad–energía al variar el incentivo de brecha asumido para el adversario (G_0 , que representa el valor de la API). A mayor incentivo, el equilibrio de Nash prescribe más escalado y por tanto mayor mitigación de ataques avanzados a costa de más energía, aproximándose asintóticamente al punto Tradicional. Es notable que incluso en su extremo más seguro ($\sim 93\%$ de mitigación avanzada) el Adaptativo consume del orden de 6,300 Joules, un orden de magnitud menos que los 45,010 del Tradicional.

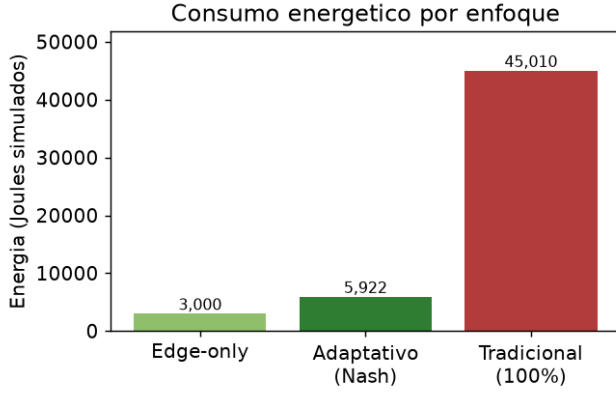


Figura 2: Consumo energético por enfoque. El Adaptativo se sitúa cerca del piso del Edge-only, muy por debajo del Tradicional.

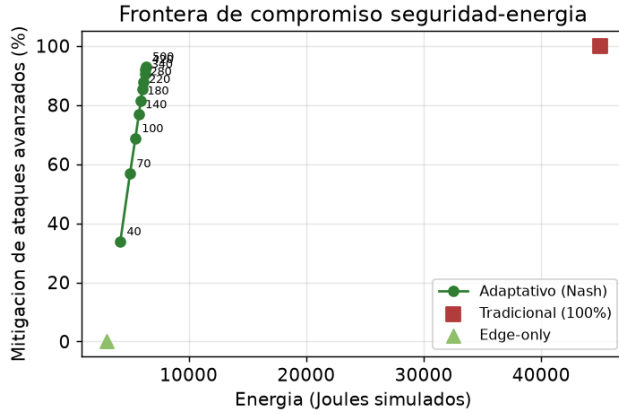


Figura 3: Frontera de Pareto seguridad-energía del enfoque Adaptativo al variar el incentivo de brecha G_0 (etiquetas junto a cada punto), con los puntos de referencia Tradicional y Edge-only.

8 Discusión

Los resultados evidencian que aleatorizar la decisión de inspección según el Equilibrio de Nash captura la mayor parte del valor de seguridad de la inspección exhaustiva con una fracción de su costo energético. La clave es la *especialización por capa*: el Edge neutraliza gratis a los bots ruidosos y el juego reserva la energía de Serverless para el tráfico con anomalía de payload, que es donde la inspección profunda aporta valor.

Una propiedad teórica relevante es que, en el equilibrio mixto, la probabilidad de escalado p queda determinada por la matriz de pagos del *Atacante* (ecuación (7)): es el incentivo del adversario —no la mera aversión al riesgo del defensor— lo que fija el nivel óptimo de aleatorización. Esto es deseable, pues vincula el gasto de recursos a la amenaza racional esperada.

Limitaciones. (i) El modelo de detección de Serverless es idealizado (detección perfecta al inspeccionar); introducir falsos negativos/positivos es trabajo futuro. (ii) Cada petición se trata como una etapa independiente; un verdadero juego estocástico multi-etapa con estado (reputación de IP, calentamiento de Serverless) permitiría políticas dependientes de la historia. (iii) La puntuación de sospecha usa heurísticas ligeras; aprenderla con datos reales mejoraría la calibración. (iv) Los costos energéticos son unidades relativas simuladas, no mediciones físicas.

9 Conclusiones

Presentamos SGE, una defensa perimetral adaptativa para APIs que formula la decisión de inspección profunda como un juego estocástico no cooperativo con información imperfecta y la resuelve mediante el Equilibrio de Nash en estrategias mixtas. Empíricamente, SGE logra un 95.5% de mitigación global y un 81.8% de mitigación de ataques avanzados con un 86.8% de ahorro energético frente a la inspección total, y expone una frontera de Pareto sintonizable según el valor de la API. El enfoque muestra que la teoría de juegos es una herramienta efectiva para alinear la seguridad con los objetivos de la computación sostenible. Como trabajo futuro proponemos extender el modelo a un juego estocástico multi-etapa con estado y aprender tanto la función de sospecha como los parámetros de utilidad a partir de trazas de tráfico reales.

Referencias

- [1] J. Nash. *Non-Cooperative Games*. Annals of Mathematics, 54(2):286–295, 1951.
- [2] L. S. Shapley. *Stochastic Games*. PNAS, 39(10):1095–1100, 1953.
- [3] M. Tambe. *Security and Game Theory: Algorithms, Deployed Systems, Lessons Learned*. Cambridge University Press, 2011.
- [4] T. Alpcan and T. Başar. *Network Security: A Decision and Game-Theoretic Approach*. Cambridge University Press, 2010.
- [5] A. Katal, S. Dahiya, and T. Choudhury. *Energy efficiency in cloud computing data centers: a survey on software technologies*. Cluster Computing, 26:1845–1875, 2023.